Definición de roles y esquema de seguridad para la base de datos relacional del proyecto Finanzas Personales

EAV 07

Alejandra Cano
Yuliana Morales
Katherine Rodríguez

1. Introducción a la Estrategia de Seguridad

El presente esquema de seguridad define las políticas y mecanismos de control de acceso diseñados para proteger la integridad y confidencialidad de la información en el ecosistema de la aplicación. La estrategia se fundamenta en un modelo de Seguridad en Capas, donde la autenticación de identidad (gestionada por el microservicio de Seguridad) actúa como la primera barrera, vinculándose con la lógica transaccional del microservicio de Finanzas.

El objetivo principal es garantizar que cada interacción con la base de datos esté sujeta al *Principio de Privilegio Mínimo y al Aislamiento de Datos por Titular*. Para lograrlo, el sistema implementa una arquitectura basada en Control de Acceso Basado en Roles (RBAC) y Seguridad a Nivel de Fila, asegurando que la relación entre el `usuario_id` (de la tabla usuario) y el `titular_id` (de la tabla `titulares_financieros`) sea el eje central de validación. De esta forma, se previene cualquier acceso no autorizado a registros sensibles como transacciones, presupuestos y metas de ahorro, manteniendo un entorno seguro tanto para el usuario final como para los roles administrativos y de soporte.

2. Modelo de Autenticación y Gestión de Acceso

Acerca de los mecanismos técnicos para validar la identidad de los usuarios y asegurar que las sesiones sean trazables y seguras. Es ideal que el sistema utilice un esquema de Autenticación Robusta basado en los siguientes pilares.

A. Resguardo de Credenciales e Identidad

La seguridad de la tabla usuario se fundamenta en la protección de la `contrasenha_hash`. No se almacenan contraseñas en texto plano; en su lugar, se utilizan algoritmos de hashing criptográficos por usuario. Además, el sistema implementa una política de Bloqueo Dinámico: tras un número definido en `intentos_fallidos`, la cuenta se inhabilita temporalmente según el campo `bloqueado_hasta`, mitigando ataques de fuerza bruta y diccionarios.

B. Gestión de Sesiones mediante Tokens

Para el acceso a los recursos del microservicio de finanzas, se implementa un modelo de Tokens de Acceso y Refresco. La tabla token permite gestionar el ciclo de vida de cada sesión de forma granular:

- Trazabilidad: Cada token está vinculado a una `ip_origen` y un dispositivo, permitiendo auditorías de acceso geográfico o por terminal.

- Revocación Inmediata: Gracias al campo booleano revocado, el sistema puede invalidar sesiones sospechosas o cerrar sesiones de forma remota sin esperar a que el token expire.

- Tipificación: El campo tipo permite diferenciar entre flujos de acceso, renovación de sesión y procesos de recuperación de cuenta, garantizando que un token de un tipo no pueda ser utilizado maliciosamente en otro flujo.

C. Integridad del Perfil

La separación entre las tablas usuario y perfil asegura que los datos de autenticación sensibles estén aislados de los datos informativos (nombres, teléfonos, etc.). Esta estructura permite actualizar la información personal del usuario sin comprometer sus credenciales de acceso, manteniendo siempre la integridad referencial a través del `usuario_id`.

3. Modelo de Autorización basado en Roles

La autorización en el sistema se gestiona mediante una estructura de Control de Acceso Basado en Roles (RBAC). Este modelo garantiza que las funciones críticas y el acceso a la información financiera estén restringidos según el perfil asignado al usuario en la tabla `rol`.

A. Matriz de Responsabilidades y Permisos

Para asegurar la correcta separación de funciones, se definen los siguientes niveles de acceso sobre las entidades del microservicio de finanzas:

Rol	**Titular Financiero (Usuario corriente)**
Alcance	Propietario de los datos
Permisos	CRUD (Crear, Leer, Actualizar, Borrar) exclusivo sobre sus propias `transacciones`, `metas_ahorro`, `presupuestos` y `categorias`.
Restricción	No tiene visibilidad sobre registros de otros usuarios, garantizada por la vinculación obligatoria entre su `token` de sesión y el `titular_id`
Rol	**Soporte técnico**

Alcance	Personal encargado de la asistencia al usuario.
Permisos	Acceso de solo lectura a la tabla `perfil` y estados generales de las `metas_ahorro` para diagnóstico de errores.
Restricción	Posee acceso denegado a los montos específicos de transacciones y presupuestos, protegiendo la privacidad del usuario incluso ante el personal interno.
Rol	**Administrador**
Alcance	Gestión global de la plataforma
Permisos	Capacidad para gestionar la tabla `usuario`, modificar la tabla `rol` y supervisar registros de `auditoria_seguridad`
Restricción	Aunque tiene control sobre la infraestructura, el acceso a la información financiera operativa está limitado a funciones de mantenimiento, sin permisos de edición sobre transacciones individuales.

B. Propagación de Roles en el Ecosistema

Cuando un usuario se autentica, el sistema extrae su `rol_id` y lo inyecta en el Contexto de Seguridad de la solicitud. Este rol viaja con el `token` de acceso, permitiendo que el microservicio de finanzas valide en milisegundos si la operación solicitada (por ejemplo, "Borrar una Meta de Ahorro") es permitida para ese nivel de usuario antes de siquiera consultar la base de datos.

4. Seguridad de Registro

Es la capa de seguridad más crítica, ya que garantiza el aislamiento lógico entre los datos de diferentes usuarios, tratando cada cuenta como un entorno privado.

Para garantizar la privacidad financiera, el sistema implementa un modelo de aislamiento lógico basado en la vinculación obligatoria entre el `usuario_id` del esquema de seguridad y el `titular_id` del microservicio de finanzas. Mediante la aplicación de políticas de Seguridad a Nivel de Fila en el motor de base de datos, se asegura que cualquier consulta ejecutada por el servicio esté filtrada por el contexto del usuario autenticado; esto impide que un titular acceda, incluso por error, a transacciones, presupuestos o metas de ahorro que no le pertenecen. Asimismo, se establecen reglas de integridad referencial que protegen la coherencia de la información ante eliminaciones o actualizaciones, manteniendo un entorno de datos estanco donde cada cuenta de usuario funciona como un repositorio privado e inaccesible para terceros.

5. Auditoría y Trazabilidad de Operaciones

El sistema garantiza la rendición de cuentas mediante un esquema de auditoría que monitorea el ciclo de vida de cada interacción. Utilizando los registros de `ultimo_acceso`, `ip_origen` y el estado de revocación de la tabla token, se establece una trazabilidad completa que permite identificar el origen y la terminal de cada sesión activa, facilitando la detección de anomalías o accesos concurrentes sospechosos. Adicionalmente, toda modificación en entidades críticas, como el estado de las `metas_ahorro` o la creación de reportes, queda vinculada al titular responsable, asegurando que exista un historial inmutable para procesos de soporte técnico o auditoría forense, fortaleciendo así la transparencia y la confianza en la gestión de los activos financieros del usuario.

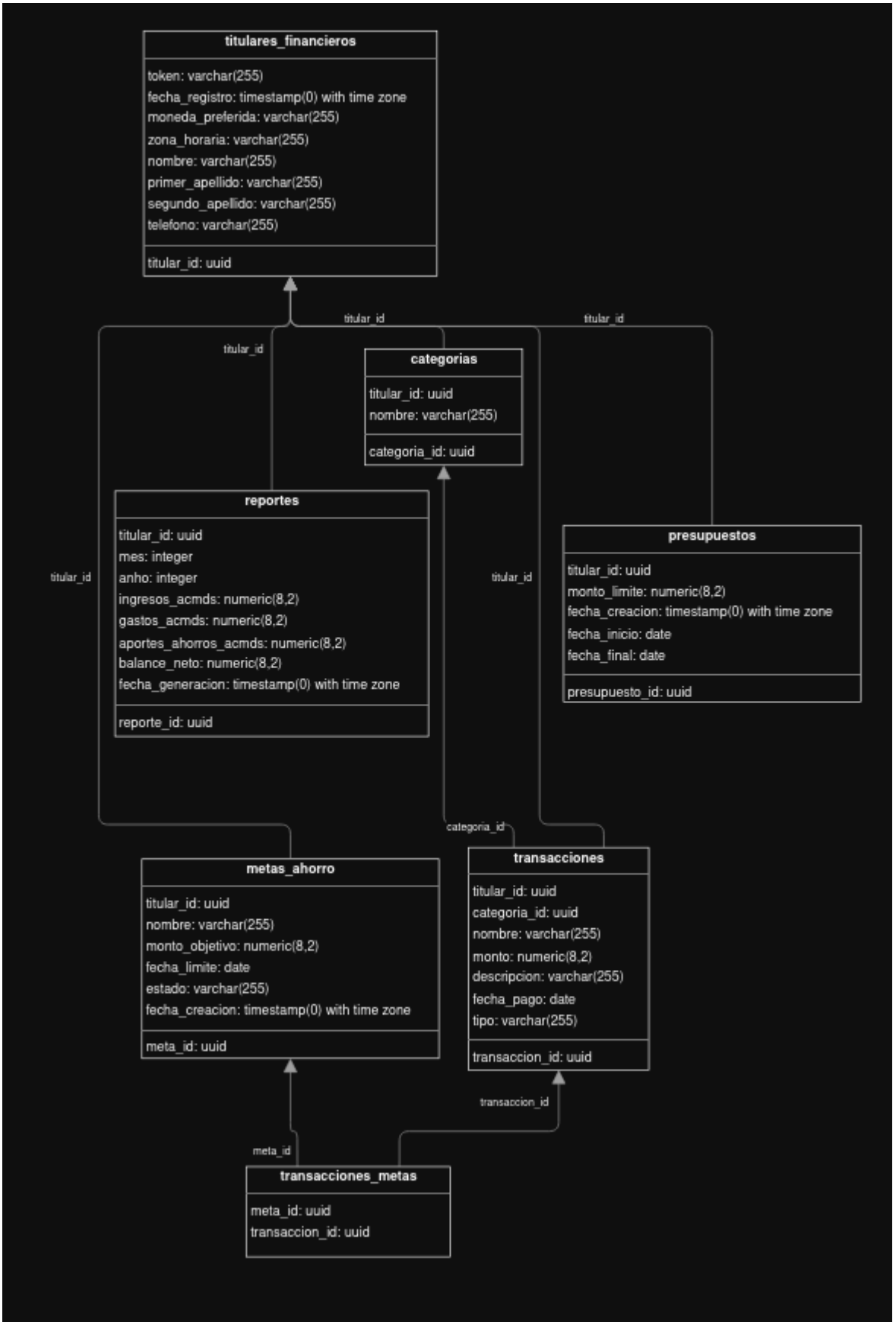

Diagrama físico del Microservicio de Finanzas

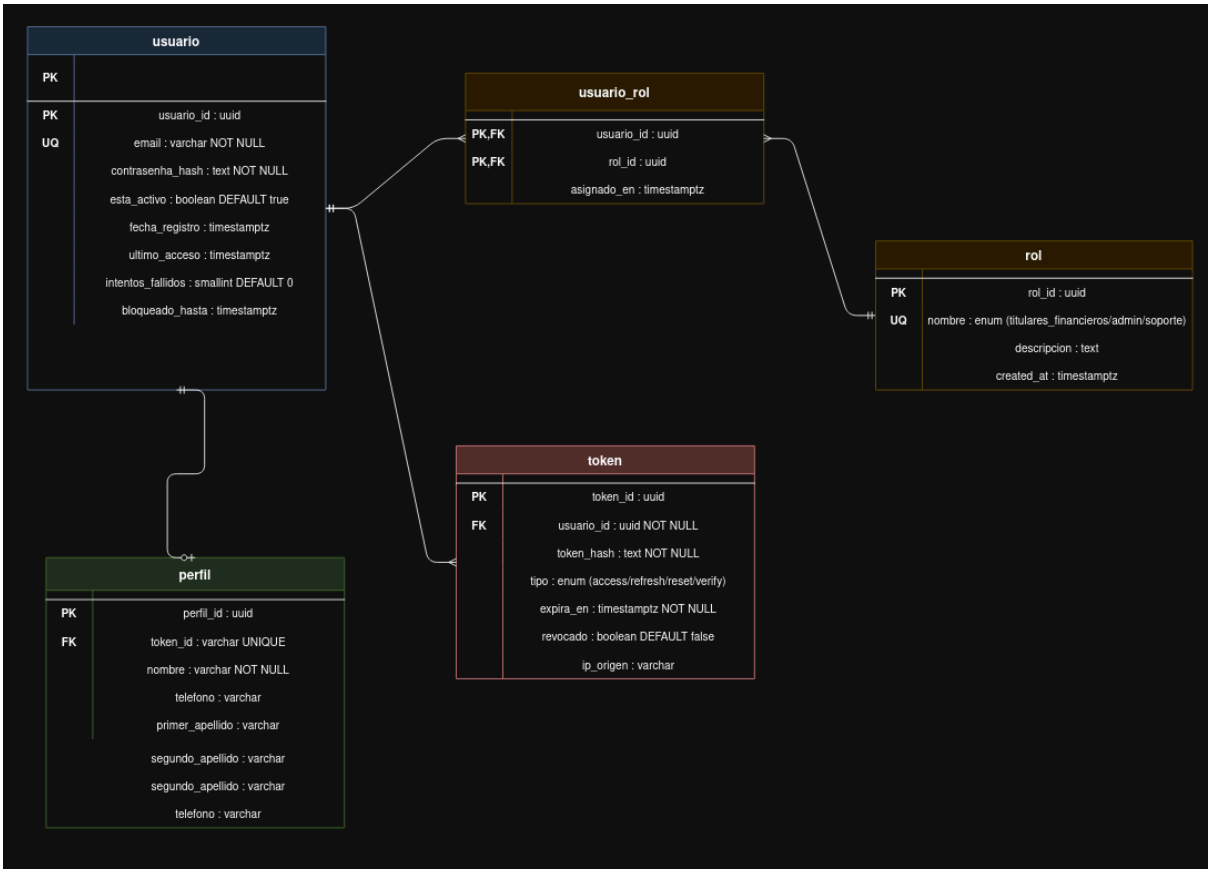

Diagrama físico del Microservicio de Seguridad